



CONTAINERKONFERANSEN 2026 • BSIDES KØBENHAVN 2026 • TRONDHEIM • COPENHAGEN

The Call Is Coming From Inside the House

Shadow AI and the data you're already losing

Alex Flowers

Founder & CEO, Groovy Security





● Finance ops · #ai-help

Tuesday · 14:07

"Here's our customer export – can you dedupe it and flag the ones with overdue invoices?"

customers_2026_q3.xlsx 41,208 rows

Nobody was attacked.

Nobody broke a rule they knew about.

41,208 customer records left the building anyway.



No malware. No phishing. No insider.

A helpful tool and a deadline.

Every control you paid for was pointed at the door.

That is what “shadow AI” actually looks like. It is not a threat actor. It is your colleagues, doing their jobs, through a channel nothing is watching.



Alex Flowers

- Founder, Groovy Security. I've spent the last two years building AI-governance tooling, so yes – I have a horse in this race.
- This talk is about the problem and a framework you can run with tools you already own. It is not a product talk. You will not see a screenshot.
- Where I describe an approach, I'll describe the class of approach, not a vendor.
- Our platform is U.S. patent pending, which is one more reason this talk stays at the framework level.
- Slides, sources and a one-page checklist are linked on the last slide.



Four parts

1

Adoption outran policy

How every department became an AI user before anyone wrote a rule.

2

Why your stack can't see it

Three assumptions DLP, CASB and the proxy were built on – and how AI broke each one.

3

The five surfaces

Browser · desktop · IDE & coding agents · workloads · MCP and tool access. Why each defeats egress controls.

4

Discover → Enforce → Audit

A governance model you can start Monday – and the two failure modes that both end in data loss.



01

PART 1

Adoption outran policy

Your employees adopted generative AI before your security team had a policy for it. That is not a criticism of your security team.



Which year was your AI policy written for?

Nov 2022



Chat in a browser

ChatGPT. Copy, paste, ask.

2023



The first public leaks

Samsung engineers paste source code; Italy's DPA suspends ChatGPT under GDPR.

2024



AI inside the apps

Copilot in Word, Excel, Teams. Assistants ship inside the tools that hold the data.

2025



Agents in the IDE

Claude Code, Codex, Cursor: the agent reads the whole repo and runs commands.

2026



Agents with tool access

MCP and connectors: the assistant pulls from Drive, Jira, GitHub, Slack on its own.

Each step: closer to the data, further from the network boundary.



Everyone is already using it. Most of them on their own accounts.

75%

of knowledge workers use generative AI at work

Microsoft / LinkedIn Work Trend Index, 2024

78%

of those bring their own AI tools – personal accounts, personal subscriptions

Microsoft / LinkedIn Work Trend Index, 2024

1 in 5

organisations reported a breach involving shadow AI in the last year

IBM Cost of a Data Breach, 2025

Shadow AI is the default state of an organisation that has not decided otherwise.



What actually goes into the prompt box

Who	What they paste	What it is, legally
Developers	Source code, API keys, .env files, customer data in test fixtures	Trade secrets · credentials
Analysts & finance	Exports, pipeline, unreleased numbers, board decks	MNPI · SOX · confidential
Legal	Contracts, privileged advice, litigation strategy	Privilege · GDPR
HR	Candidate notes, compensation, performance and health leave	Special-category data
Clinicians & caseworkers	Discharge summaries, referrals, case notes	Health data · GDPR Art. 9
Everyone	"Summarise this email thread" – with the whole thread attached	All of the above

None of these rows looks like an attack in any log you currently have.



Spring 2023: three leaks, then a ban

What happened

Engineers pasted proprietary source code and internal meeting notes into a public chatbot to debug and summarise.

Three separate incidents in roughly twenty days.

Response: generative AI banned on company devices and networks.

What a ban actually does

Usage moves to personal phones, home laptops, and the next tool on the list.

Telemetry drops to zero. The leak rate does not.

The organisation now has less visibility than before the ban – and believes it has more.

Reasonable reflex in 2023. Now we know what it costs.



02

PART 2

Why your stack can't see it

DLP, CASB and the secure web gateway were built for files and known SaaS endpoints. Generative AI broke three assumptions they all share.



Three assumptions your controls were built on

Sensitive data looks like a pattern

- Card numbers, national IDs, keywords, fingerprints of known files.
- A discharge summary, a forecast, or a contract clause matches none of them.
- Free text has no signature.

Egress happens at the boundary

- Inspect at the proxy, the mail gateway, the USB port.
- Copilot in Excel never leaves the app. Desktop apps pin certificates. Agents run in the IDE.
- The prompt is sent from inside the tool that holds the data.

The destination list is finite

- Allow-list sanctioned SaaS, block the rest.
- Thousands of AI wrappers, a new one every day, plus the one built into every product you already own.
- Category lists lag by weeks. Users don't.



Where the existing stack goes blind

Control ↓ Surface →	Web chat (paste / upload)	Desktop app (cert-pinned)	IDE agent (reads the repo)	Workload → model API	MCP / connectors (AI pulls data)
Secure web gateway / proxy	Domain block; content only with TLS break	Blind: pinning	Sees bytes, not intent	Not on that path	Sees OAuth flows, not tool calls
Network DLP	Patterns in JSON stream	Blind	Patterns only	Partial, patterns only	Blind
CASB	Sanctioned tenants via API; unsanctioned: category block	Blind	Blind	Blind	Sees consents in sanctioned IdP
Endpoint DLP (classic)	Clipboard + file patterns	File patterns on drop	Blind to agent context	N/A	Blind
Identity / SSO logs	Only if enterprise SSO is used	Only if SSO	Rarely	Service accounts	OAuth consent log ✓

Red = cannot see it. Amber = sees bytes or patterns, not meaning. Green = a real signal you already have.



You can't hand your certificate to a pinned app

How break-and-inspect works

Your proxy terminates TLS with a corporate root CA pushed to every device, reads the bytes, re-encrypts to the vendor.

It works only where the client trusts that CA: browsers and the OS trust store.

That buys you browser traffic to web AI tools, as bytes. A bespoke parser per vendor API can turn it into partial browser coverage.

Where it stops

Certificate-pinned apps – ChatGPT, Claude, Copilot on desktop and mobile, many CLIs – refuse your CA. The handshake fails, so you bypass or block. Both lose visibility.

Copilot in Office is the same tenant-to-tenant API as your mail. Nothing to split on.

Agents and SDKs ship their own CA bundles; QUIC slips past most inspection; and even inspected, bytes are not intent.

What it is still good for

Discover: which hosts, from which devices and clusters, how often. DNS and proxy logs are the cheapest AI inventory you own.

Coarse control: block the consumer domain where a sanctioned tenant exists.

Not enforce. Full-interaction coverage has to happen at the point of interaction, inside the browser, the app, the agent.

Network tools find the traffic. They cannot govern the interaction.



Block the domain, and watch what happens

Personal phone

Same prompt, same file, photographed off the screen if needed.

The 1,001st tool

A wrapper on a domain your category list has never heard of.

Personal account on the corporate laptop

Consumer tier, default training-on-your-data terms.

A browser extension

"Summarise this page" – installed in ten seconds, ships the DOM.

Tethering

Hotspot on, proxy off, problem solved (for them).

When security says no, the data still leaves. It just stops telling you.



03

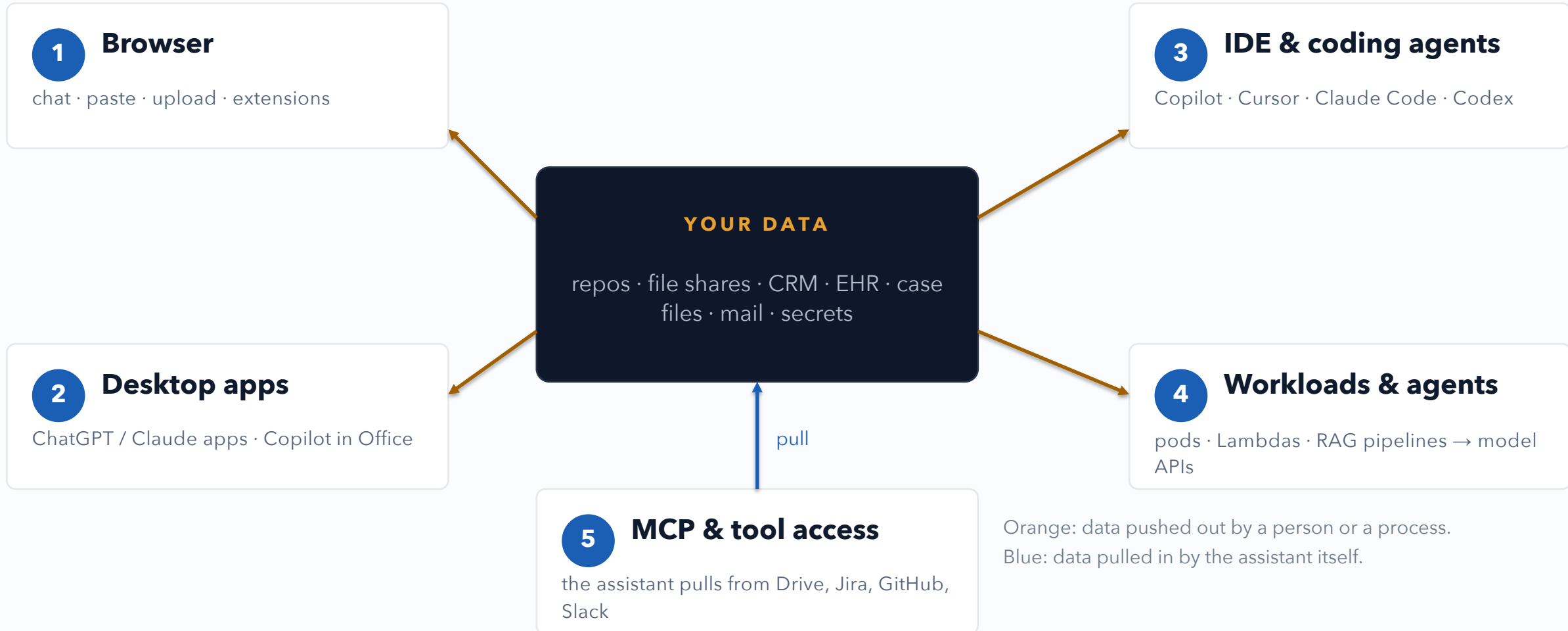
PART 3

The five surfaces

Browser · desktop apps · IDE and coding agents · workloads and internal agents · MCP and tool access. Each one defeats conventional egress controls in a different way.



Five ways out of the house





1 The browser

Where it started, and still the biggest volume.

WHAT LEAVES

- Pasted text: emails, exports, code, case notes.
- File uploads: the whole spreadsheet, the whole PDF.
- “Summarise this page” extensions that ship the page.
- Personal accounts on managed devices – consumer terms, training on by default.

WHY YOUR STACK CAN'T SEE IT

- The prompt is a JSON field in a streaming API call. TLS inspection sees bytes; it cannot tell a recipe from a discharge summary.
- Thousands of tools and wrappers; category lists lag by weeks.
- A block sends the user to the phone in their pocket.

WHAT VISIBILITY WOULD TAKE

- See the prompt at the moment of send, inside the browser, before it leaves.
- Know which account: personal vs enterprise tenant.
- Classify meaning, not patterns – and do it in the time it takes to press Enter.



2 Desktop apps

The assistant moved inside the app that holds the data.

WHAT LEAVES

- Native ChatGPT / Claude / Gemini apps: drag a file in, done.
- Copilot inside Word, Excel, Outlook, Teams – the document is the prompt.
- Screen-aware features: “what's on my screen?”
- Mobile versions of all of the above.

WHY YOUR STACK CAN'T SEE IT

- Certificate pinning: the proxy sees a TLS handshake it cannot break.
- No browser, so no extension, no DOM, no web hooks.
- Copilot in Excel never crosses the network boundary you inspect – it's tenant-to-tenant.

WHAT VISIBILITY WOULD TAKE

- OS-level observation: accessibility APIs, file-drop hooks, app inventory via MDM.
- Tenant-level controls for the assistants embedded in your productivity suite.
- Treat the app catalogue as part of the AI footprint.



3 IDE & coding agents

The agent sends context you never typed – and it also executes.

WHAT LEAVES

- Whole files, .env, git history, terminal output, attached as context automatically.
- Credentials in fixtures and config; customer data in test databases.
- The agent runs commands, edits files, opens PRs – with the developer's permissions.

WHY YOUR STACK CAN'T SEE IT

- No browser. A terminal and a socket to a model API.
- What leaves is chosen by the agent, not the human, so there is nothing to pattern-match at send time.
- Inbound risk too: prompt injection through repo content and instruction files (OWASP LLM01).

WHAT VISIBILITY WOULD TAKE

- Agent-native hooks: most agents now expose pre-tool-use / pre-send hooks you can wire policy into.
- Transcript and session audit after the fact.
- Secrets hygiene: what isn't on disk can't be sent.



4 Workloads & internal agents

Nobody is typing. The pod is.

WHAT LEAVES

- Services, batch jobs, Lambdas and RAG pipelines calling model APIs with production data.
- Service-account API keys in env vars and config maps.
- Multi-provider sprawl: OpenAI, Anthropic, Bedrock, Vertex, Mistral, self-hosted... per team.

WHY YOUR STACK CAN'T SEE IT

- To the network it's HTTPS to a well-known host on 443, which your egress policy allows.
- No human, no endpoint agent, no browser – the classic controls have nothing to attach to.
- Inventory usually lives in a spreadsheet nobody updates.

WHAT VISIBILITY WOULD TAKE

- Inventory from what you have: egress DNS/flow logs vs. a list of model API hosts; secrets-manager keys by provider.
- Observe in-process or beside the workload (SDK, sidecar, transcript) rather than MITM-ing your own production traffic.
- Per-workload policy: which data classes may go to which provider.



5 MCP & tool access

The newest exit – and the only one that points inward.

WHAT LEAVES

- Assistants get connectors: Drive, SharePoint, Jira, GitHub, Slack, mail, calendar.
- The AI now **pulls** your data on its own, at scale, with the user's full permissions.
- A personal assistant subscription with a corporate Drive grant is a cross-tenant leak.

WHY YOUR STACK CAN'T SEE IT

- The grant is an OAuth consent – a green button the user clicks once, forever.
- Tool calls are not prompts; nothing in the prompt-scanning stack sees a ``search_files`` call.
- Indirect injection: a poisoned document or tool description steers the agent.

WHAT VISIBILITY WOULD TAKE

- Consent governance in your IdP: who may grant what, to which apps; audit existing grants now.
- Allow-list MCP servers and connectors; treat tool descriptions as untrusted input.
- Audit tool calls, not just prompts.



Five surfaces, five different blind spots

Surface	What leaves	Why the stack is blind	What visibility takes
1 Browser	Prompts, pastes, uploads	Bytes without meaning; endless destinations	See the prompt at send, in the browser
2 Desktop apps	Files dropped into pinned apps; the document itself	Certificate pinning; no browser hooks	OS-level hooks; MDM app inventory
3 IDE & agents	Context the agent chooses; agent actions	Nothing to pattern-match; injection inbound	Agent-native hooks; transcript audit
4 Workloads	Production data from services and pipelines	Looks like any HTTPS egress; no endpoint	Egress + secrets inventory; observe beside the workload
5 MCP & tools	Data the assistant pulls with your permissions	It's an OAuth grant, not a prompt	Consent governance; tool-call audit



04

PART 4

Discover → Enforce → Audit

Why pattern-matching fails, where the detector has to live, and a governance loop you can start on Monday.



Which of these contains regulated data?

A

"Check this discharge summary for errors: 54M, chest pain on exertion, troponin raised, started on dual antiplatelet therapy, follow-up cath booked..."

B

"Here's our Q3 pipeline by account – help me build the Q4 forecast we're taking to the board next week."

C

"Draft a reply to the Ashworth family about restructuring the trust before the sale closes."

All three. Health data · unreleased financials · privileged advice. Zero regex hits.



Pattern matching fails in both directions

Misses the real thing

A discharge summary with no patient name.

A forecast that is just numbers and account names.

Source code with the secret in a variable called `cfg`.

Blocks the harmless thing

Any 16-digit number. Any string called "password".

The compliance training deck that explains what an SSN is.

Test fixtures that look exactly like production.

The detector has to read. Intent and context, not tokens – a language classifier, small or large, tuned to your data classes.



Your classifier is an egress channel too

The trap

Every prompt is sent to a second cloud so it can be checked for whether it should have been sent to the first.

Health, tax, defence, and public-sector data now transits a vendor you didn't assess for it.

Data-residency and transfer rules apply to the guardrail, not just the AI.

Ask any vendor (including me)

Where does the classifier run – my infrastructure, yours, or a third party's?

What is retained after the verdict – the prompt, the class, or nothing?

Does it work with no internet at all?

What's changed

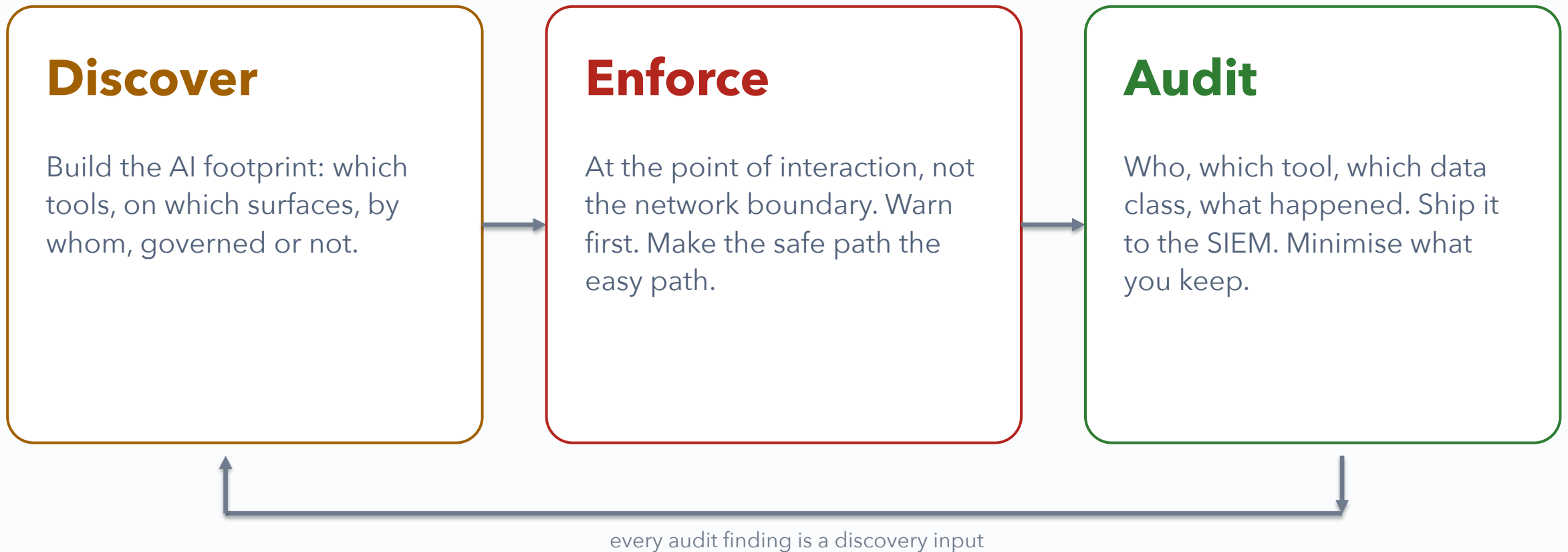
Open-weight models now run well on a single GPU box in your own cloud account or data centre.

Send-time latency budgets of a few hundred milliseconds are achievable.

Air-gapped is a deployment option, not a research project.



Discover → Enforce → Audit – and around again





What you can see for free, this week

- **IdP consent logs.** Entra 'Enterprise applications' / Google 'third-party app access': every AI app a user has ever granted a scope to.
- **DNS and proxy logs** against a list of model-API and AI-tool hosts. Group by source: laptops vs. clusters.
- **Expense reports.** Search for the subscription names. This is where BYO-AI lives.
- **MDM inventory:** installed apps and browser extensions, matched against an AI-tool catalogue.
- **IDE extension inventory + secrets manager** grouped by provider: which teams hold which model-API keys.
- **Cluster egress** flow logs to model endpoints, per namespace.
- **An amnesty survey.** "Tell us what you use and we will not punish you" – and mean it.

Output: the AI footprint – tool × surface × who × governed / ungoverned. A table, before it is a tool.



It's a ladder, not a wall

Allow

Most prompts. Log the class, not the content.

Nudge

A warning at the moment of send. Changes behaviour; costs nothing.

Redact

Strip identifiers, send the rest. The user still gets their answer.

Redirect

"Use the sanctioned tool for this." Enterprise tenant, no-training terms.

Block

Rare, high-confidence, with a reason and an appeal path.

Design rules

Warn first. Blocks teach people to route around you; nudges teach them the policy.

Provide the sanctioned path before you close the unsanctioned one.

Decide fail-open vs. fail-closed on purpose. Bricked workflows get uninstalled.

Policies by group: clinicians ≠ developers ≠ finance.

MDM is the hard layer: force-install, managed browser policy, device trust.



Any endpoint control falls in about a minute

How

Disable the extension. Block the backend host in /etc/hosts.

Use a personal device. Use an uncovered tool.

Wait for the control to fail open when the network blips.

So design for

The cooperative majority – governed, nudged, audited.

Visibility of the rest: a device that stops reporting is the finding.

MDM and device trust where you need a guarantee, not a hope.

Never buying “tamper-proof”.

Governance is for people who want to do the right thing. Detection is for the rest.



The record your auditor is about to ask for

One event, every surface

Who (identity, group) · which tool · which surface

Data class detected (not the content)

Verdict: allowed / nudged / redacted / redirected / blocked – and overridden, by whom, why

Timestamp, device, and whether the control was actually running

Shipped to the SIEM you already have

Who is going to ask

GDPR – records of processing (Art. 30), security of processing (Art. 32), transfers (Ch. V)

EU AI Act – AI literacy for staff (Art. 4, in force) and deployer obligations phasing in

NIS2 – in Danish law since 2025; Norway via the EEA track

ISO/IEC 42001 – the AI management-system standard your customers will start citing

Your own DPO, on Monday

Minimise: log the verdict and the class, not the prompt. You can prove governance without hoarding the data you were protecting.



"Ban it" and "ignore it" both end in data loss

Ban everything

Usage moves to personal devices and accounts.

Telemetry goes to zero; the leak rate does not.

Productivity and talent go with it.

False sense of control.

Govern it

Sanctioned path with the right terms.

Point-of-use nudges and redaction.

An audit trail you can hand to a regulator.

The only position with visibility.

Ignore it

Silent egress across five surfaces.

Found by incident, by a journalist, or by a regulator.

No record to show you tried.

Also a false sense of control.

The data leaves in all three. Only one of them tells you.



Thirty days, four moves

Week 1

Discover

Pull IdP consents, DNS/proxy hits, expense lines, and cluster egress against an AI-host list. Run the amnesty survey. Write the footprint table.

Week 2

Decide

Publish a one-page AI-use policy naming the sanctioned tools and the data classes that never leave. Fix the consent settings in your IdP.

Week 3

Nudge

Turn on warn-mode at one surface – the browser is cheapest. No blocks yet. Watch what changes.

Week 4

Audit

Get one AI-usage event, with data class and verdict, into your SIEM. Show it to your DPO.

Then: review the footprint monthly, watch for new tools weekly, and revisit the policy every quarter.

WHY I CARE ABOUT THIS



Groovy Security was founded on this problem.

Whiteout AI is what we built for it: governance at the point of interaction, across all five surfaces, with the classifier running on infrastructure you control.

U.S. PATENT PENDING

If any of this matched your Tuesday, come and find me. I'm here all day and happy to walk through your AI footprint one-to-one – no pitch required.

alex@groovysec.com groovysec.com/talks
linkedin.com/in/alexander-flowers-a233ba207



Alex Flowers

Founder & CEO, Groovy Security



SLIDES • SOURCES • CHECKLIST



The call is coming from inside the house.
It isn't an attacker. It's Tuesday, 14:07,
and someone has a deadline.
Make the safe path the easy path.

Alex Flowers • alex@groovysec.com

Slides, sources and the 30-day checklist: groovysec.com/talks

Whiteout AI · U.S. patent pending · Containerkonferansen 2026 · BSides København 2026



[GROOVYSEC.COM/TALKS](https://groovysec.com/talks)



Sources

- Microsoft & LinkedIn, 2024 Work Trend Index – “AI at work is here. Now comes the hard part.” (75% use gen-AI at work; 78% BYO-AI).
- IBM, Cost of a Data Breach Report 2025 – shadow-AI incidents and the cost premium associated with them.
- Samsung / ChatGPT source-code incidents, April-May 2023 – reported by Bloomberg, TechCrunch and Korean press; subsequent internal ban.
- Garante per la protezione dei dati personali, 31 March 2023 – temporary limitation on ChatGPT processing under GDPR.
- Cyberhaven, 2023 – share of data pasted into ChatGPT classified as confidential by the employer.
- OWASP Top 10 for LLM Applications – LLM01: Prompt Injection.
- Regulation (EU) 2024/1689 (AI Act): Art. 4 AI literacy (applies from 2 Feb 2025); deployer obligations under Art. 26; phased application dates.
- Regulation (EU) 2016/679 (GDPR): Art. 9, 28, 30, 32; Chapter V. Directive (EU) 2022/2555 (NIS2). ISO/IEC 42001:2023.
- Model Context Protocol – specification (2024-) and published research on tool-description poisoning (2025).